

Invaria Security Review Brief

TaskForge demonstration | Product progress, business impact, and review flow

Purpose

This brief explains what the Invaria demo does today, how a repository moves through the analysis flow, and why the results matter to a business reviewer. The main conclusion is that the TaskForge demonstration is ready to show: it imports the sample repository, maps supported code paths, surfaces evidence-backed candidates, and explains their possible business impact with the local Gemma model. Human review remains the final decision point.

What to show in the review

- Open the TaskForge Executive summary to start with the business view: 16 potential risks, the affected areas, and the review call to action.
- Choose a heatmap area, then use the risk journey to show how one endpoint could lead to a business consequence.
- Open the finding to show evidence, assumptions, source references, local Gemma context, and the confirm, dismiss, or keep-open decision.
- Switch to the security graph to show the route-to-data path behind the business summary.

Current demonstration status

Area	Status	What this means for tomorrow
Repository ingestion	Working for TaskForge	The TaskForge repository has imported successfully. Broader repository testing remains a next step.
Code understanding	Working with coverage limits	Supported structures identify routes, handlers, inputs, and data access. TaskForge maps 19 endpoints, while source coverage still needs expansion.
Security graph	Demo ready	The graph links a request to its connected code and data path for focused investigation.
Potential findings	Demo ready	Static checks produce source-linked candidates that need human review.
Gemma business impact	Connected locally	The local model produces advisory business context and affected-area labels.
Evidence and review	Demo ready	Finding details retain references, assumptions, and review actions.

The current workspace

The Executive summary is the default completed-scan view. It turns the technical result into a plain-language discussion: what needs attention, which areas of the business could be affected, and which item the reviewer should inspect first.

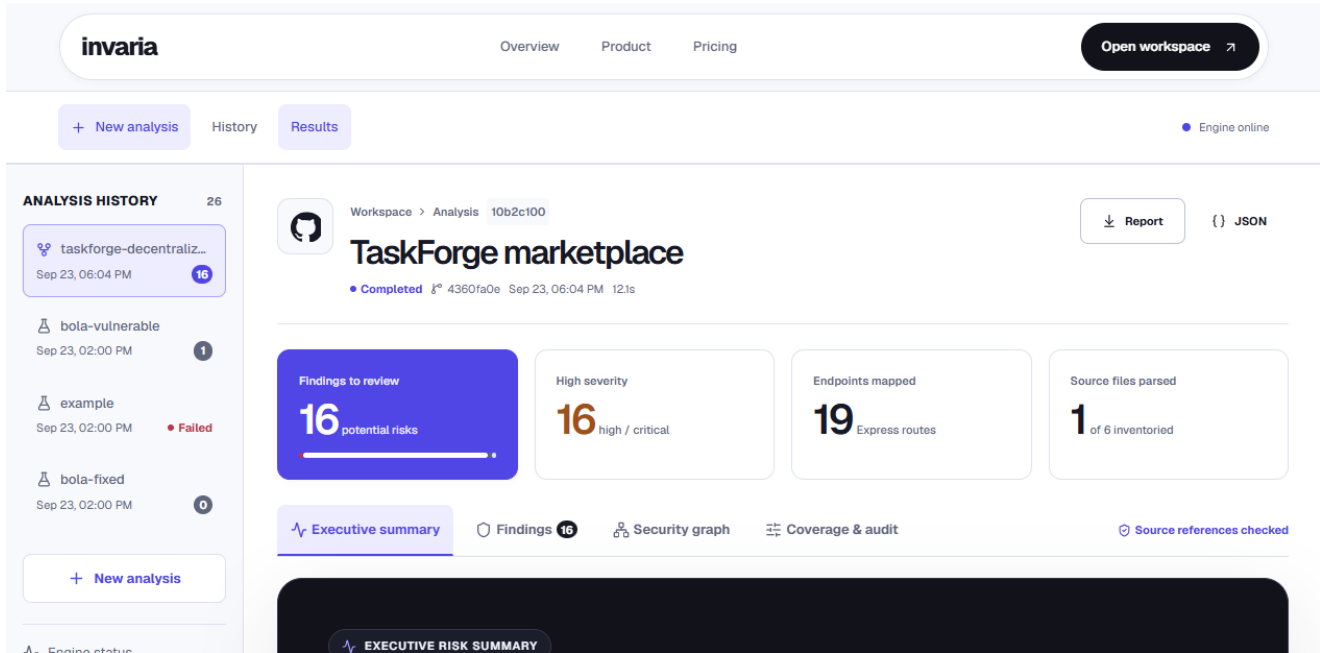


Figure 1. Current TaskForge Executive summary in the Invaria workspace.

How to read this screen

- The headline and action button identify the immediate review workload without claiming that a vulnerability is proven.
- Scorecards keep the scan size, business areas, high-priority routes, and review progress visible together.
- The heatmap and journey make the impact conversation accessible before a reviewer opens source-level detail.

Why this matters in the real world

The TaskForge sample represents a decentralized compute marketplace. Its routes manage job creation, job results, lender profiles, marketplace listings, balances, and transaction-related actions. If an authorization or data-access weakness is confirmed in these paths, the consequence can extend beyond one technical issue.

Potential business area	If a weakness is confirmed	What a reviewer needs to decide
Customer and partner trust	Unauthorized viewing of job or user information can reduce confidence in the marketplace.	Does the route enforce ownership or a role check before returning data?
Marketplace operations	Changing job status, results, or acceptance flows without the right permission can disrupt delivery and dispute handling.	Which user or service is allowed to perform this action?
Data confidentiality	Job details, lender information, and transaction records may expose sensitive commercial information.	Which fields are sensitive and who should be able to retrieve them?
Financial workflows	Balance, lender, or transaction-related paths may affect reconciliation and user confidence.	What additional controls or audit checks are required before release?

These are possible consequences of findings under review. They are not evidence that an incident occurred. Invaria deliberately separates advisory business wording from the exact source evidence used to support a finding.

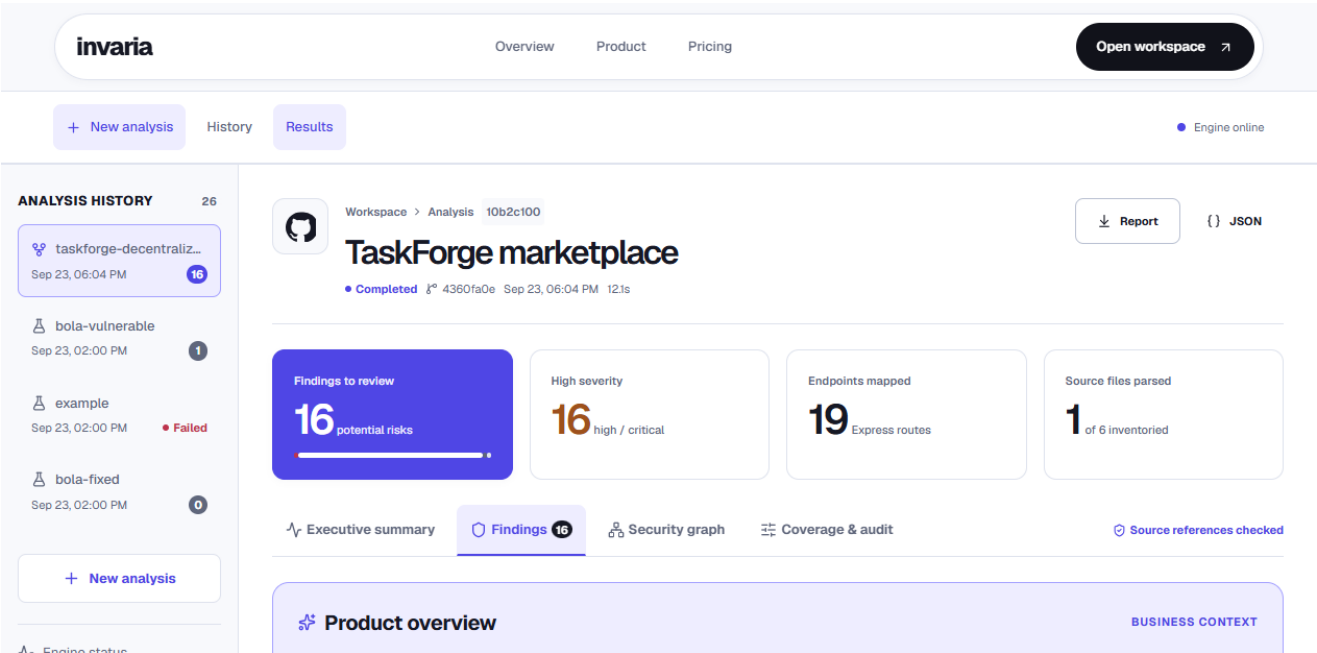


Figure 2. Findings view with the product overview and local Gemma business-impact context.

The seven stage security review flow

The workflow follows one simple principle: every business-facing message should lead back to code evidence and then to a human decision.

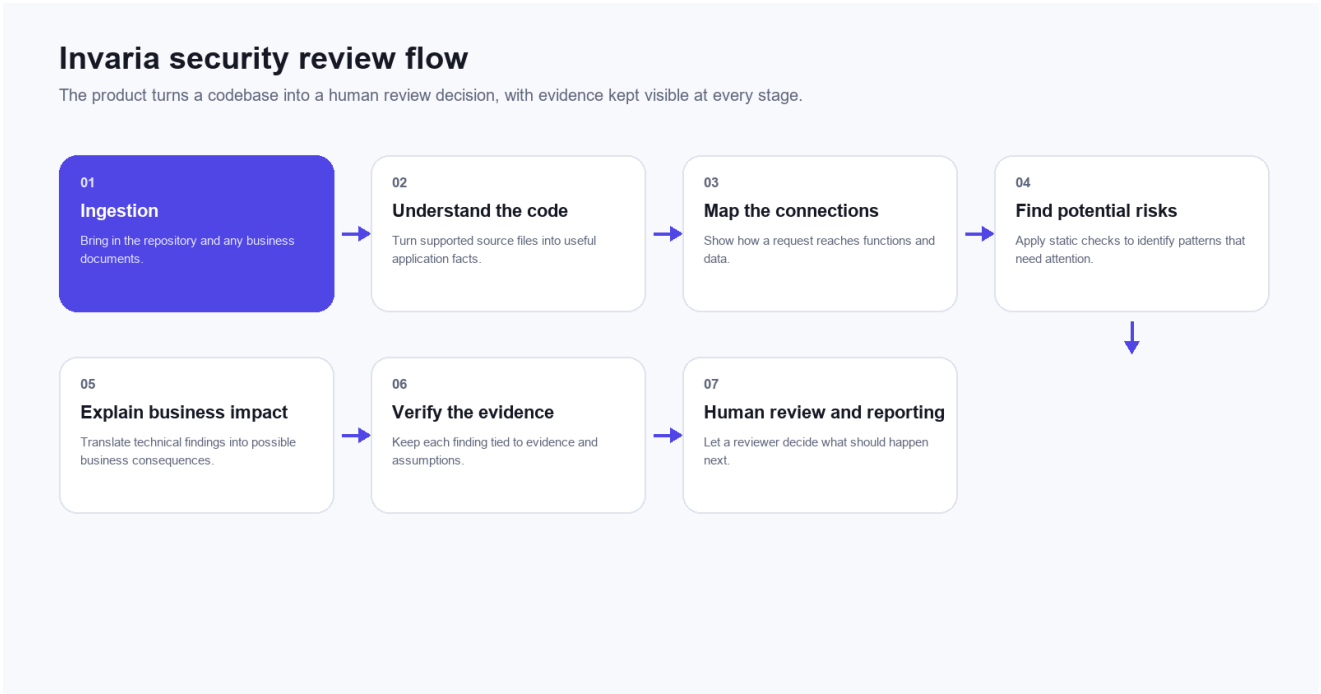


Figure 3. The complete Invaria flow from repository intake to human review.

Stage by stage details

The following pages explain the input, product action, reviewer output, and current scope for every stage.

01 Ingestion

Bring in the repository and any business documents.

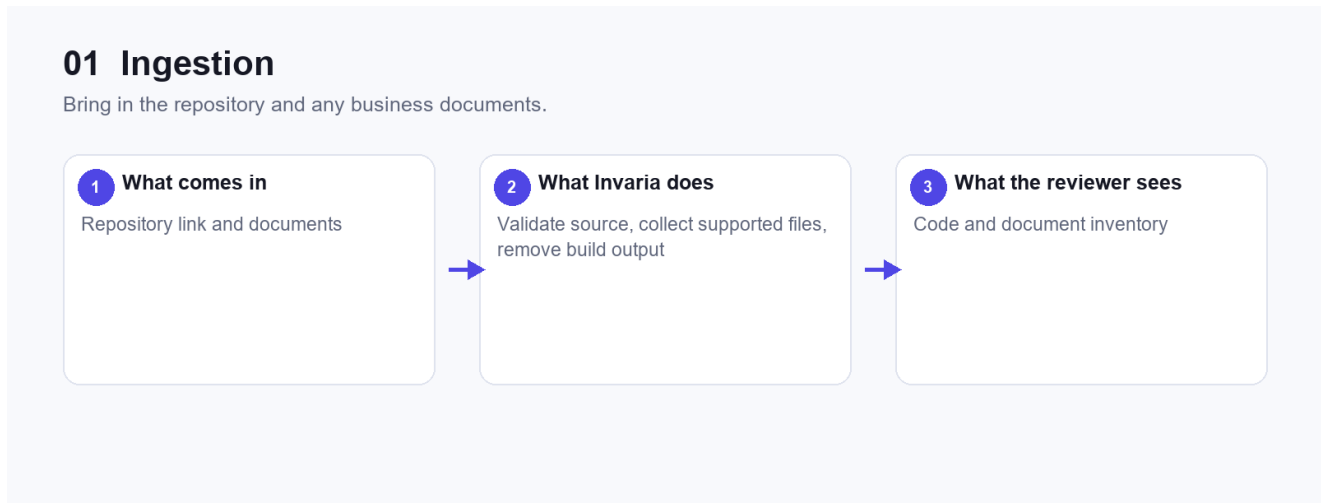


Figure 4. Ingestion flow.

For TaskForge the repository import completed. New external repositories still need broader verification.

02 Understand the code

Turn supported source files into useful application facts.

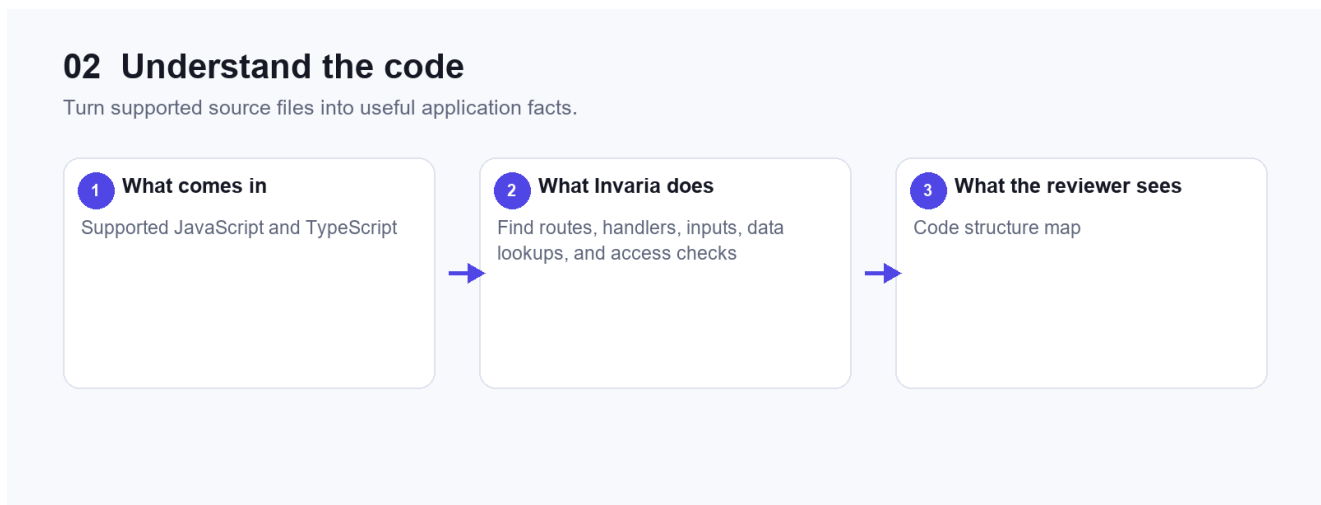


Figure 5. Understand the code flow.

TaskForge maps 19 endpoints. Parsing coverage is still limited to supported patterns and files.

03 Map the connections

Show how a request reaches functions and data.

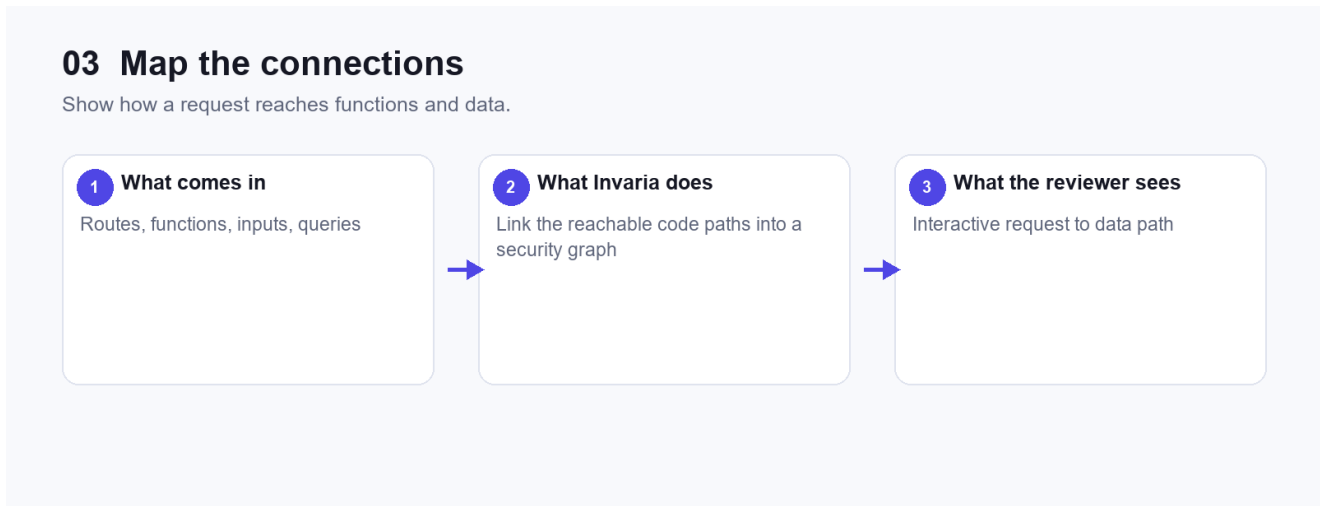


Figure 6. Map the connections flow.

The demo graph makes one endpoint path easy to inspect without reading raw source first.

04 Find potential risks

Apply static checks to identify patterns that need attention.

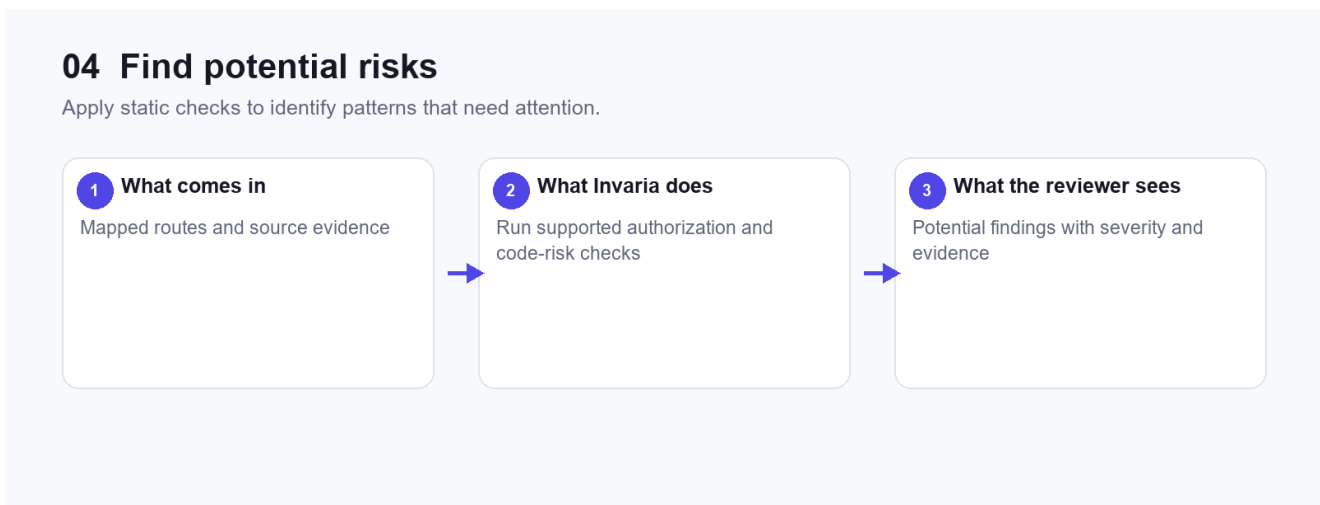
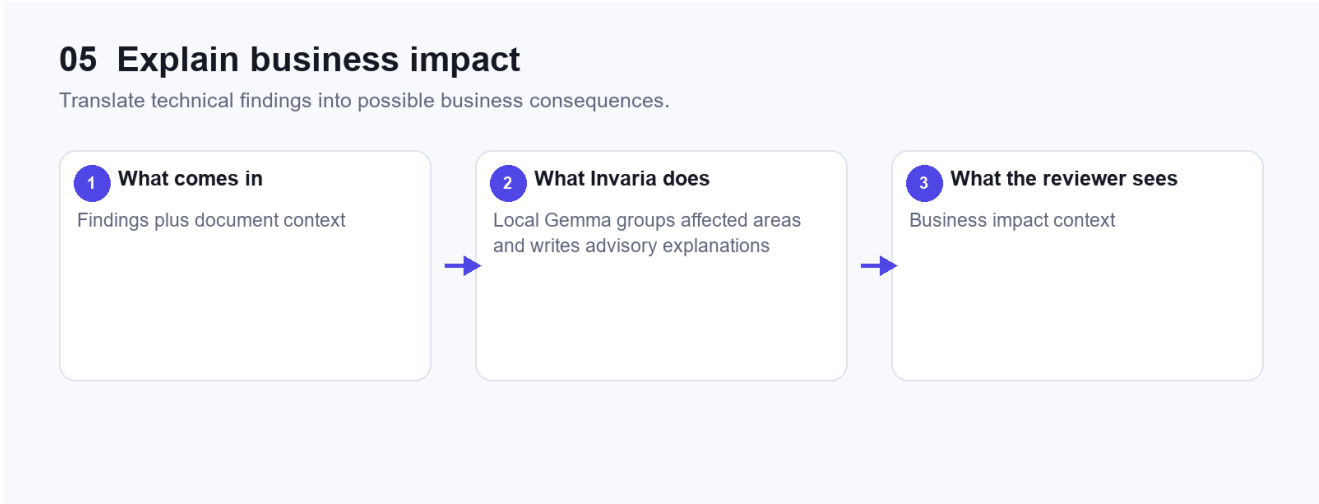


Figure 7. Find potential risks flow.

TaskForge currently shows 16 potential risks. These are review candidates, not proven incidents.

05 Explain business impact

Translate technical findings into possible business consequences.



07 Human review and reporting

Let a reviewer decide what should happen next.

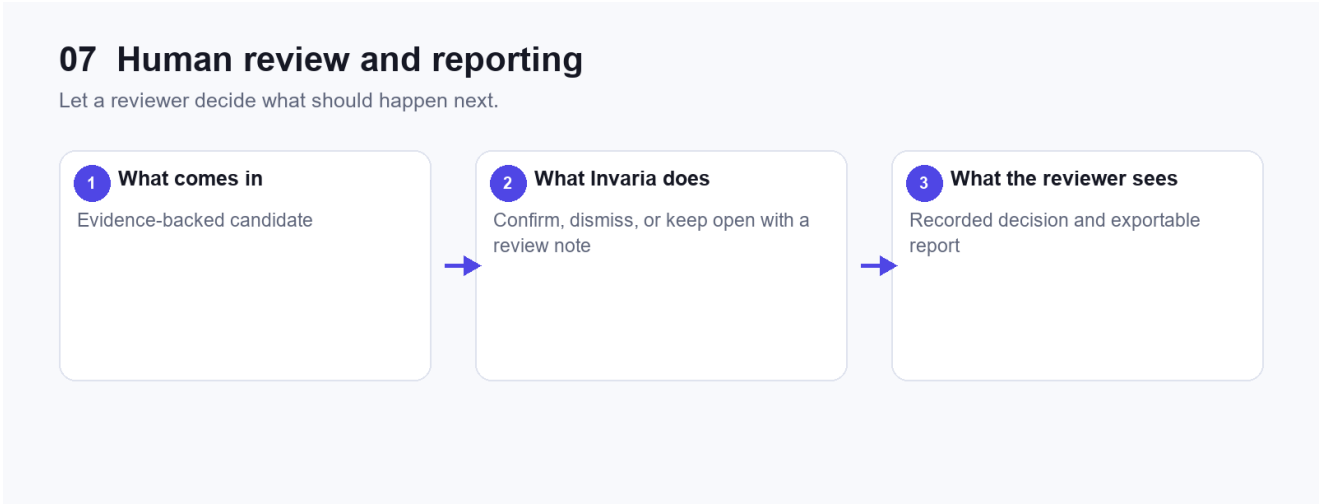


Figure 10. Human review and reporting flow.

This stage remains human-led. The product supports the decision; it does not make it automatically.

Evidence and the security graph

The security graph is the bridge between the Executive summary and detailed evidence. A reviewer can select a route and see the connected inputs, functions, and data access steps. This helps the conversation move from “why it matters” to “show me why this is being reviewed.”

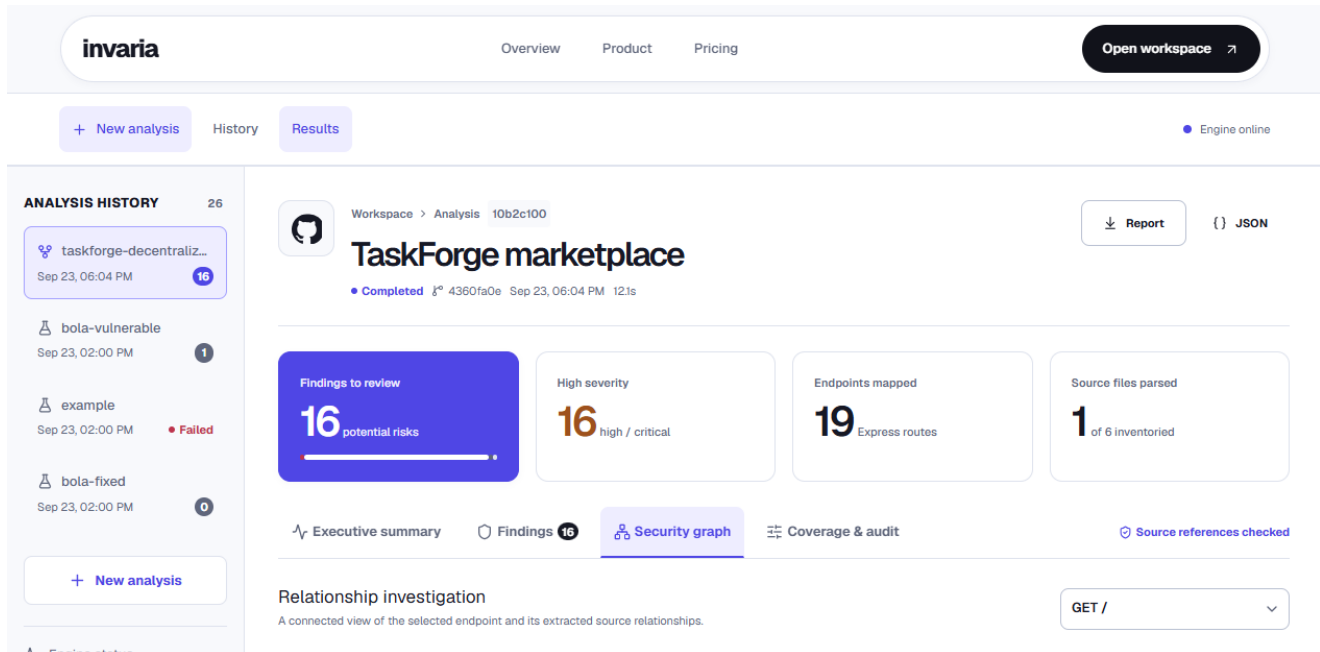


Figure 11. Security graph view showing a supported route-to-code path.

What has been delivered so far

- A working TaskForge repository analysis flow with the current supported static checks.
- A workspace with repository history, results navigation, finding details, evidence references, graph exploration, and report export actions.
- A local Gemma business-impact workflow that uses uploaded documents when useful and clearly labels generated wording as advisory.
- An Executive summary designed for a non-technical review: scorecards, heatmap, risk journey, balanced severity language, and an explicit human review action.
- A refined responsive interface with keyboard focus states and subtle interaction feedback for the demo flow.

Future outcome and next steps

The immediate goal after the review is to broaden the evidence coverage while preserving the same review-first experience. The product should become more useful as it understands more languages, frameworks, document types, and application-specific authorization patterns.

Next outcome	Why it helps	Measure of progress
Broader source coverage	More files and supported framework patterns make the analysis represent more of a real application.	Share of source files parsed and endpoints mapped.
Richer business context	Better documents and curated business areas make the Gemma explanations more specific and useful.	Reviewer feedback on relevance and clarity.
More precise checks	Additional evidence rules reduce noise and reveal more meaningful patterns.	Confirmed versus dismissed finding ratio.
Review workflow maturity	Saved decisions and exports support collaboration, follow-up, and an audit trail.	Time from finding to documented decision.

Recommended closing message for the review

Invaria already provides a working path from a TaskForge repository to a business-facing review screen. The next investment is not a new dashboard; it is deeper source coverage and more precise evidence so that the same workflow can support a wider range of real applications with increasing confidence.